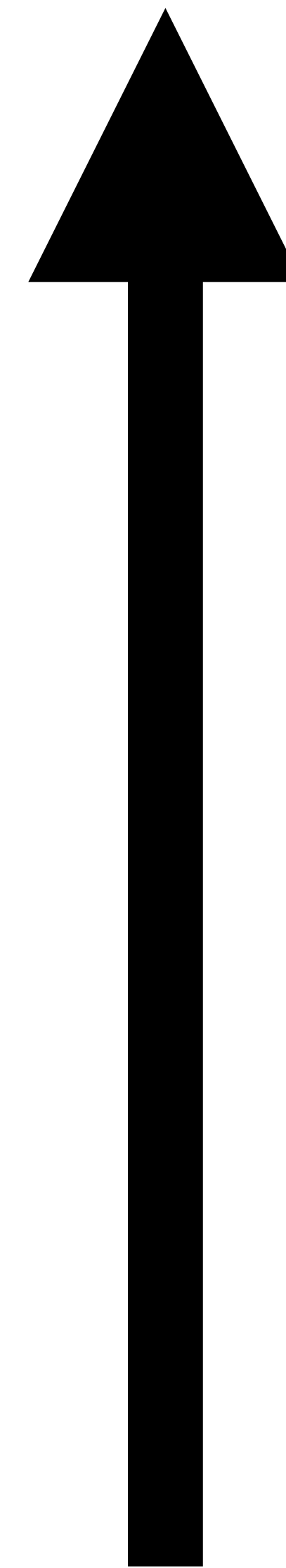
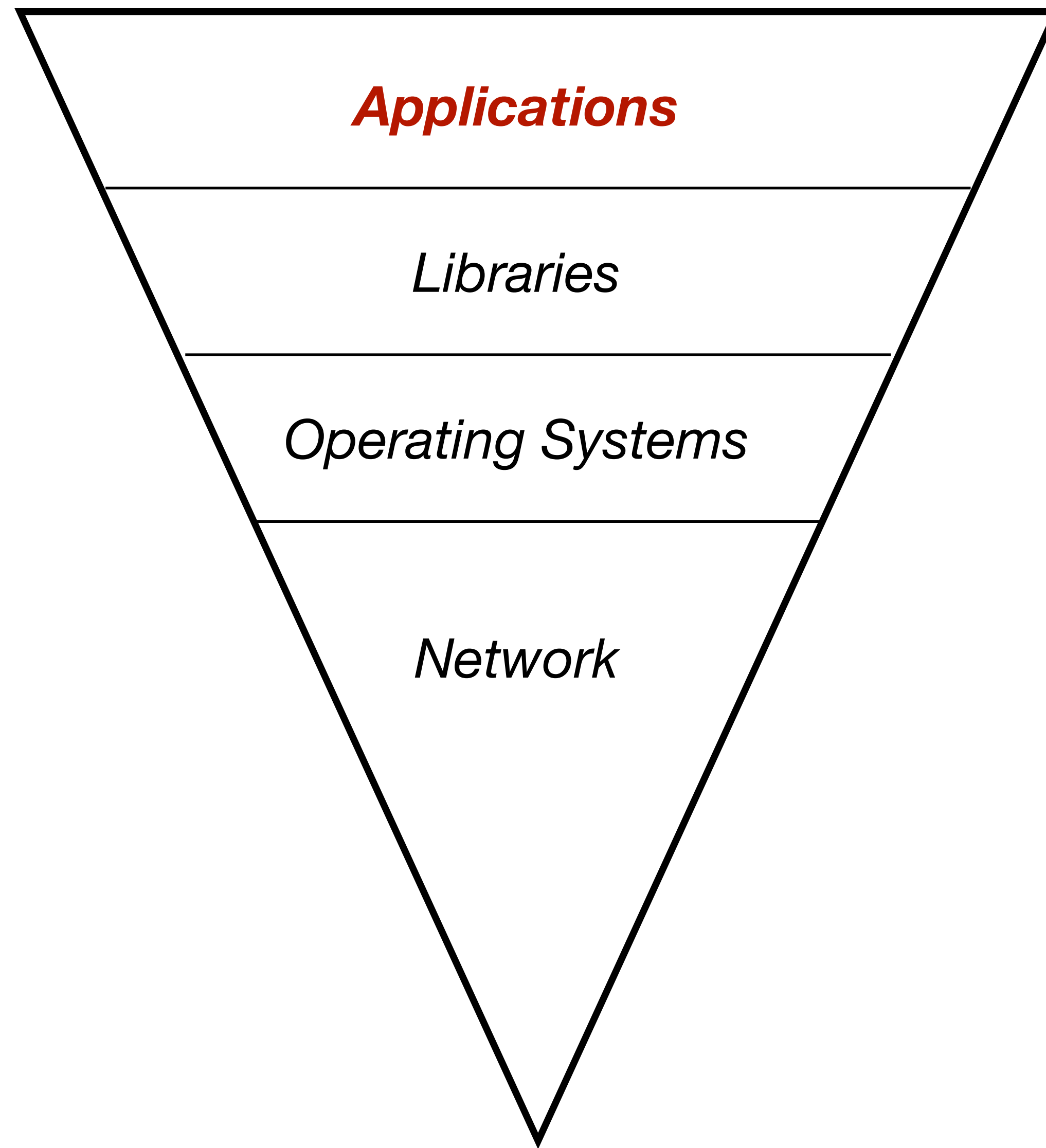


Threat Modelling with STRIDE

Dr. Ramokapane





Over time

Microsoft's 1990's philosophy:

“ship it Tuesday and get it right by V3”

2002: Bill Gates announces the Trustworthy Computing Initiative

2004: Turned into a structured process, the SDL
(<http://microsoft.com/sdl>)

Microsoft offers many (free) tools and templates to support SDL

“Trustworthy Computing is the highest priority for all the work we are doing. We must lead the industry to a whole new level of Trustworthiness in computing.”



Provide Training

Ensure everyone understands security best practices.

[Learn more >](#)



Define Security Requirements

Continually update security requirements to reflect changes in functionality and to the regulatory and threat landscape.

[Learn more >](#)



Define Metrics and Compliance Reporting

Identify the minimum acceptable levels of security quality and how engineering teams will be held accountable.

[Learn more >](#)



Perform Threat Modeling

Use threat modeling to identify security vulnerabilities, determine risk, and identify mitigations.

[Learn more >](#)



Establish Design Requirements

Define standard security features that all engineers should use.

[Learn more >](#)



Define and Use Cryptography Standards

Ensure the right cryptographic solutions are used to protect data.

[Learn more >](#)



Manage the Security Risk of Using Third-Party Components

Keep an inventory of third-party components and create a plan to evaluate reported vulnerabilities.

[Learn more >](#)



Use Approved Tools

Define and publish a list of approved tools and their associated security checks.

[Learn more >](#)



Perform Static Analysis Security Testing (SAST)

Analyze source code before compiling to validate the use of secure coding policies.

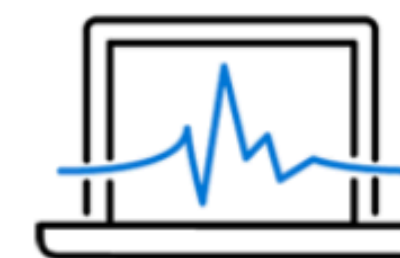
[Learn more >](#)



Perform Dynamic Analysis Security Testing (DAST)

Perform run-time verification of fully compiled software to test security of fully integrated and running code.

[Learn more >](#)



Perform Penetration Testing

Uncover potential vulnerabilities resulting from coding errors, system configuration faults, or other operational deployment weaknesses.

[Learn more >](#)



Establish a Standard Incident Response Process

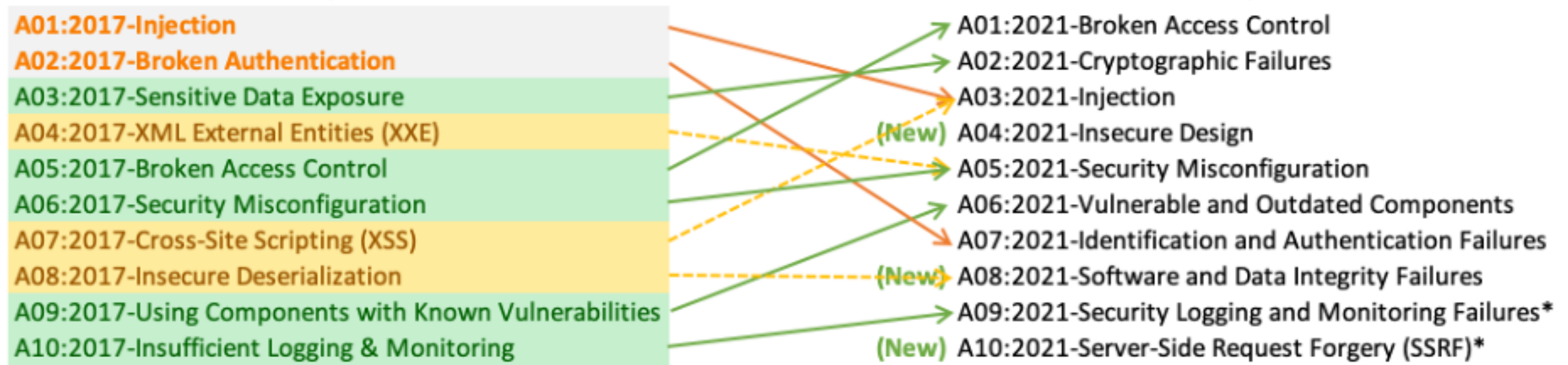
Prepare an Incident Response Plan to address new threats that can emerge over time.

[Learn more >](#)

TOP 10

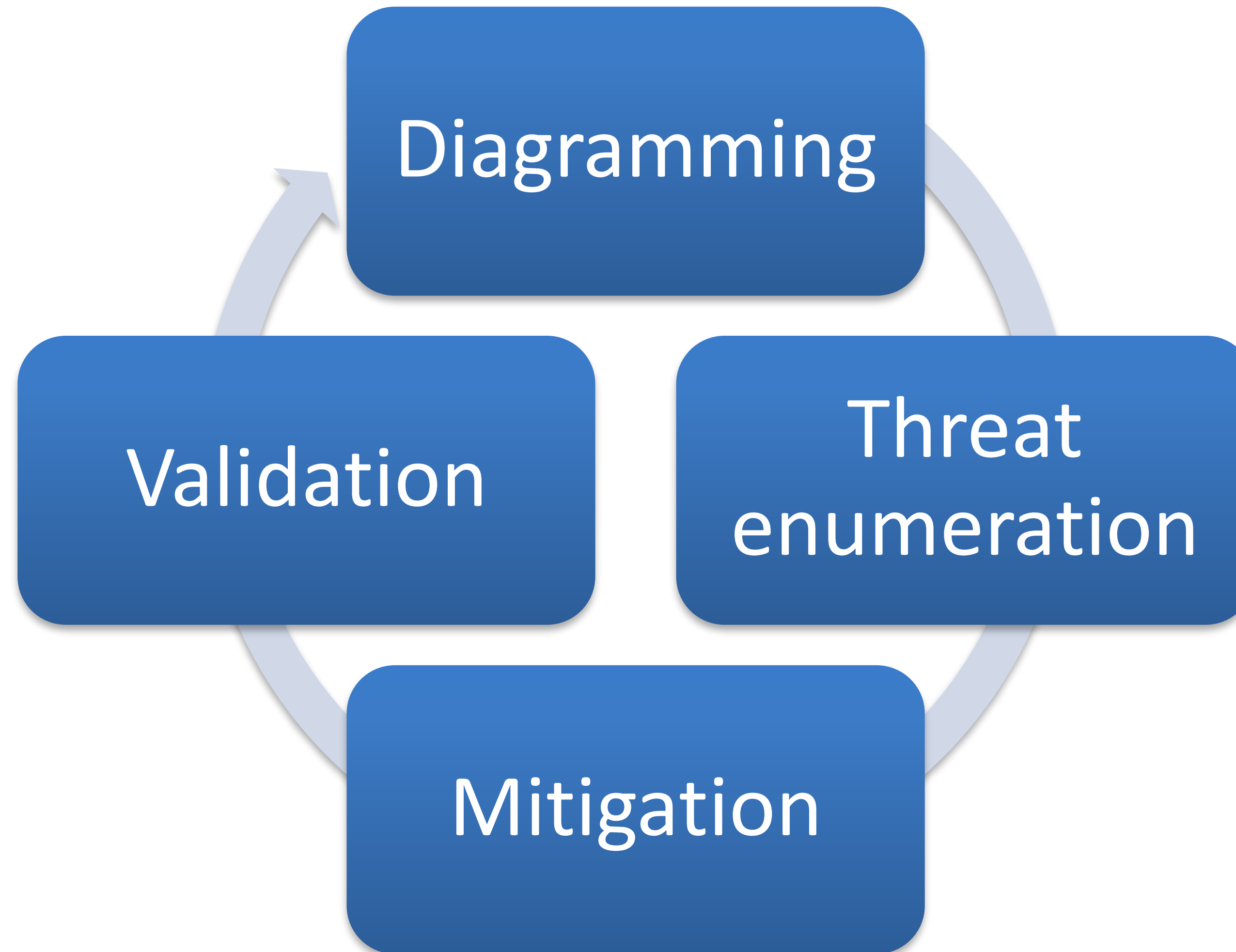
2017

2021



* From the Survey

Threat Modelling



Spoofing

Tampering

Repudiation

Information Leakage

Denial of Service

Elevation of Privilege

Spoofing

Authentication

Tampering

Integrity

Repudiation

Non-repudiation

Information Leakage

Confidentiality

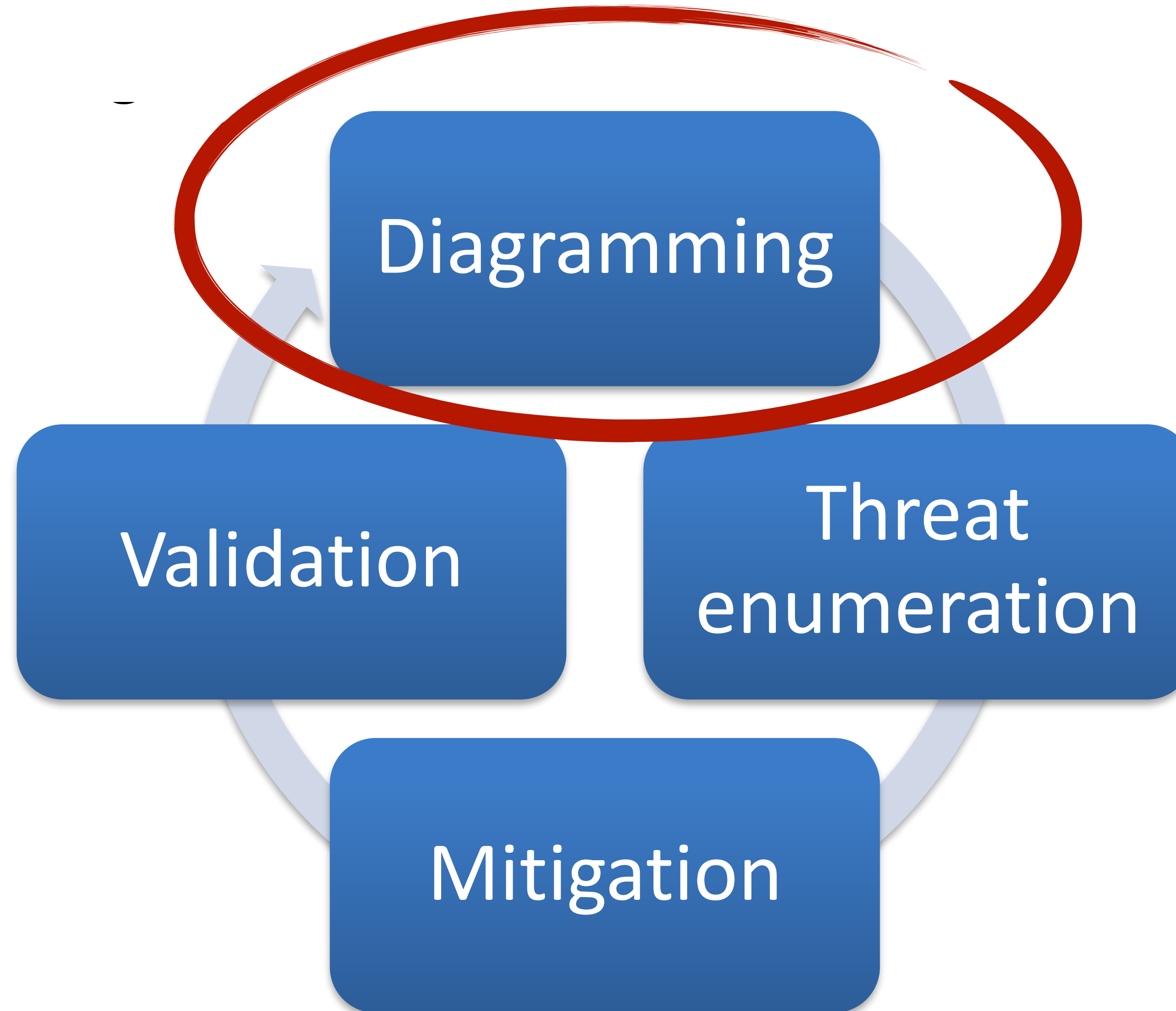
Denial of Service

Availability

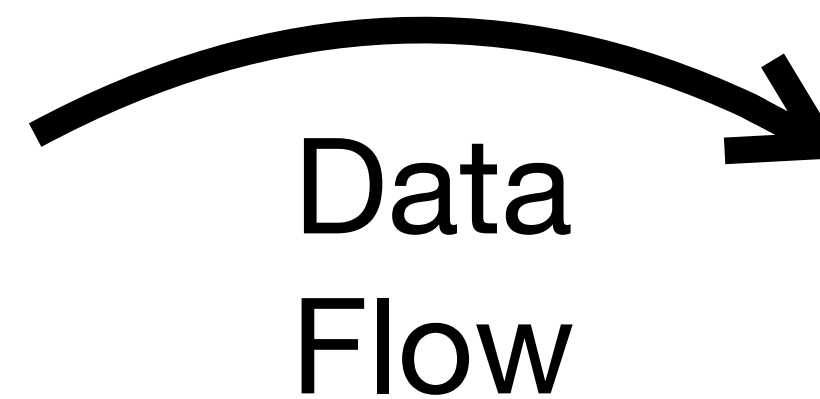
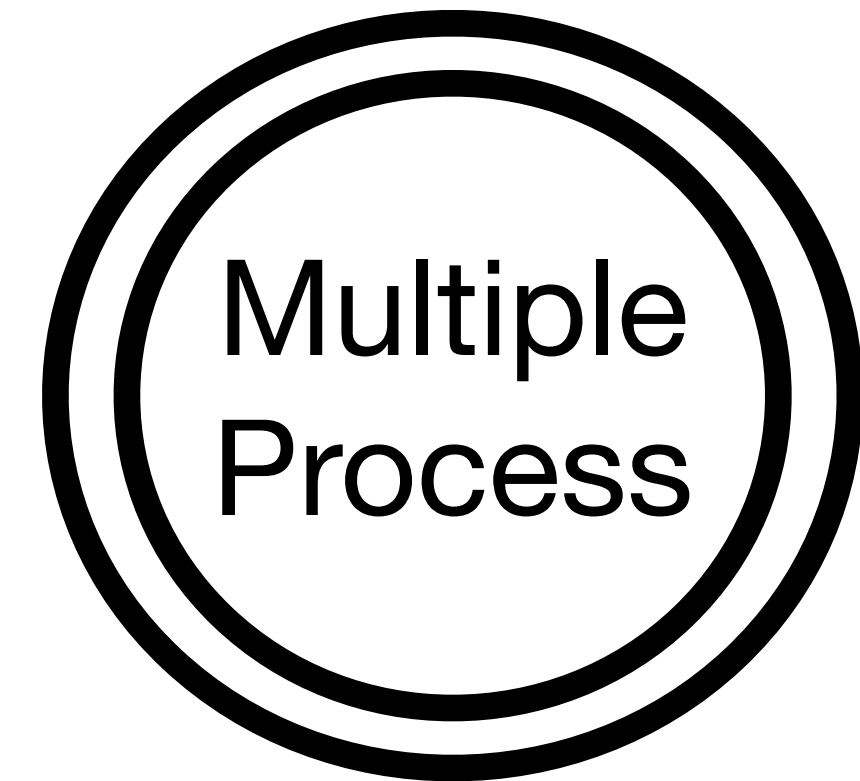
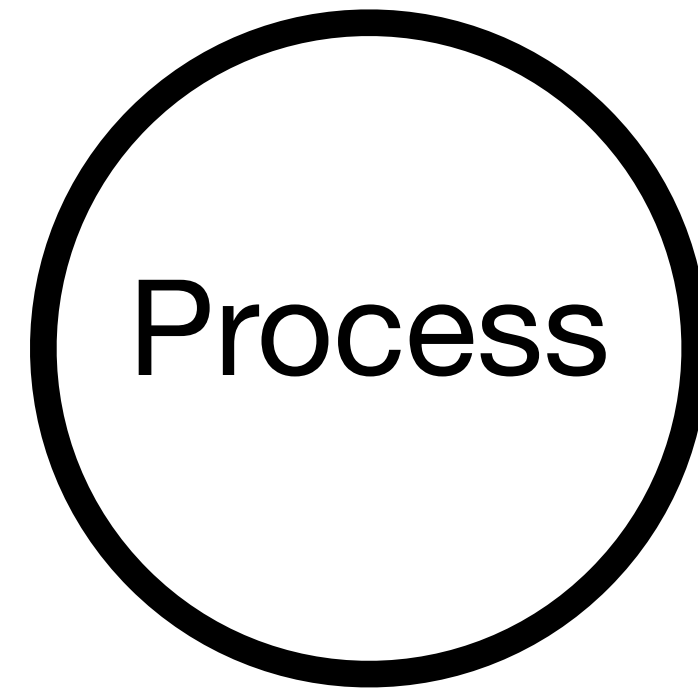
Elevation of Privilege

Authorisation

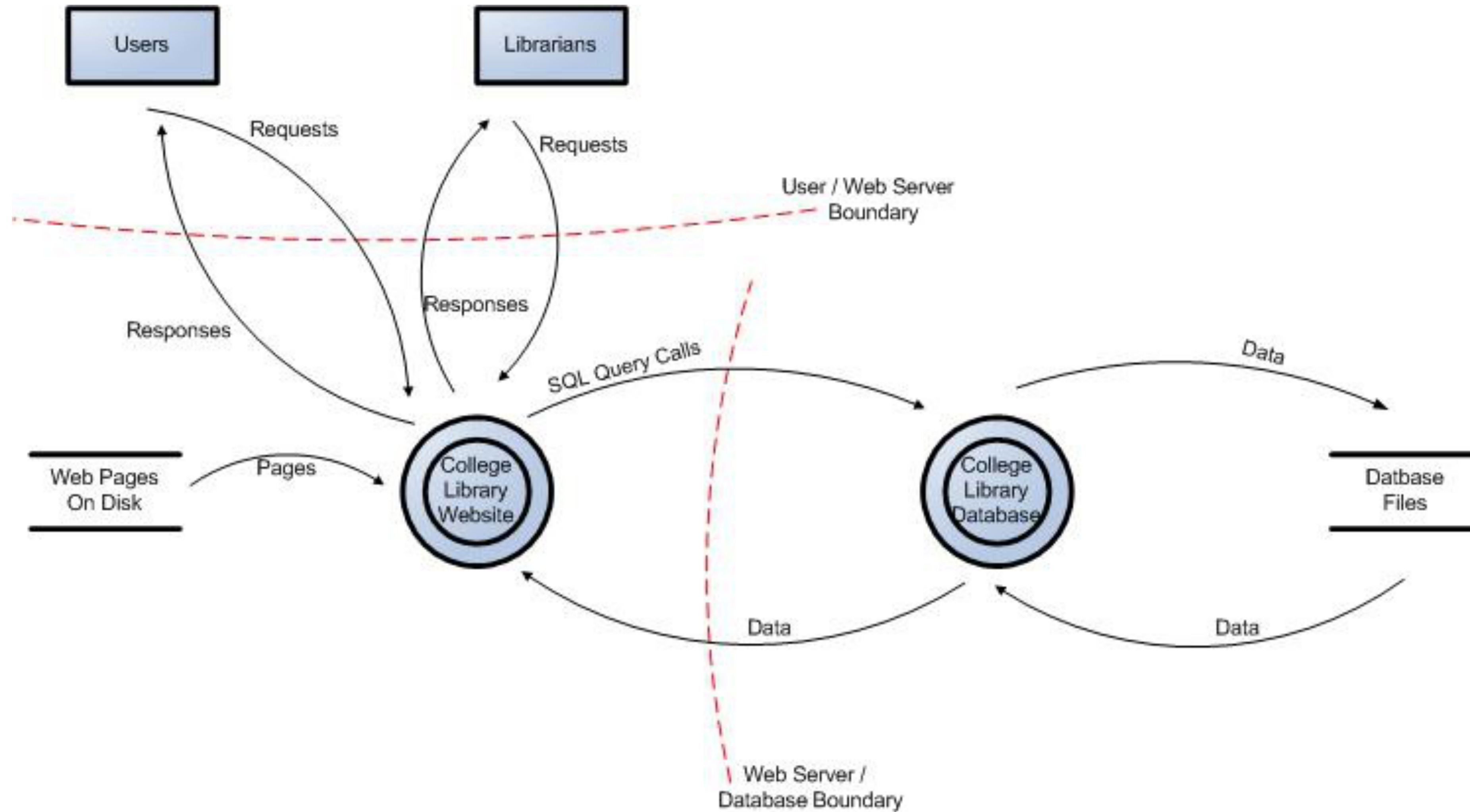
Threat Modelling



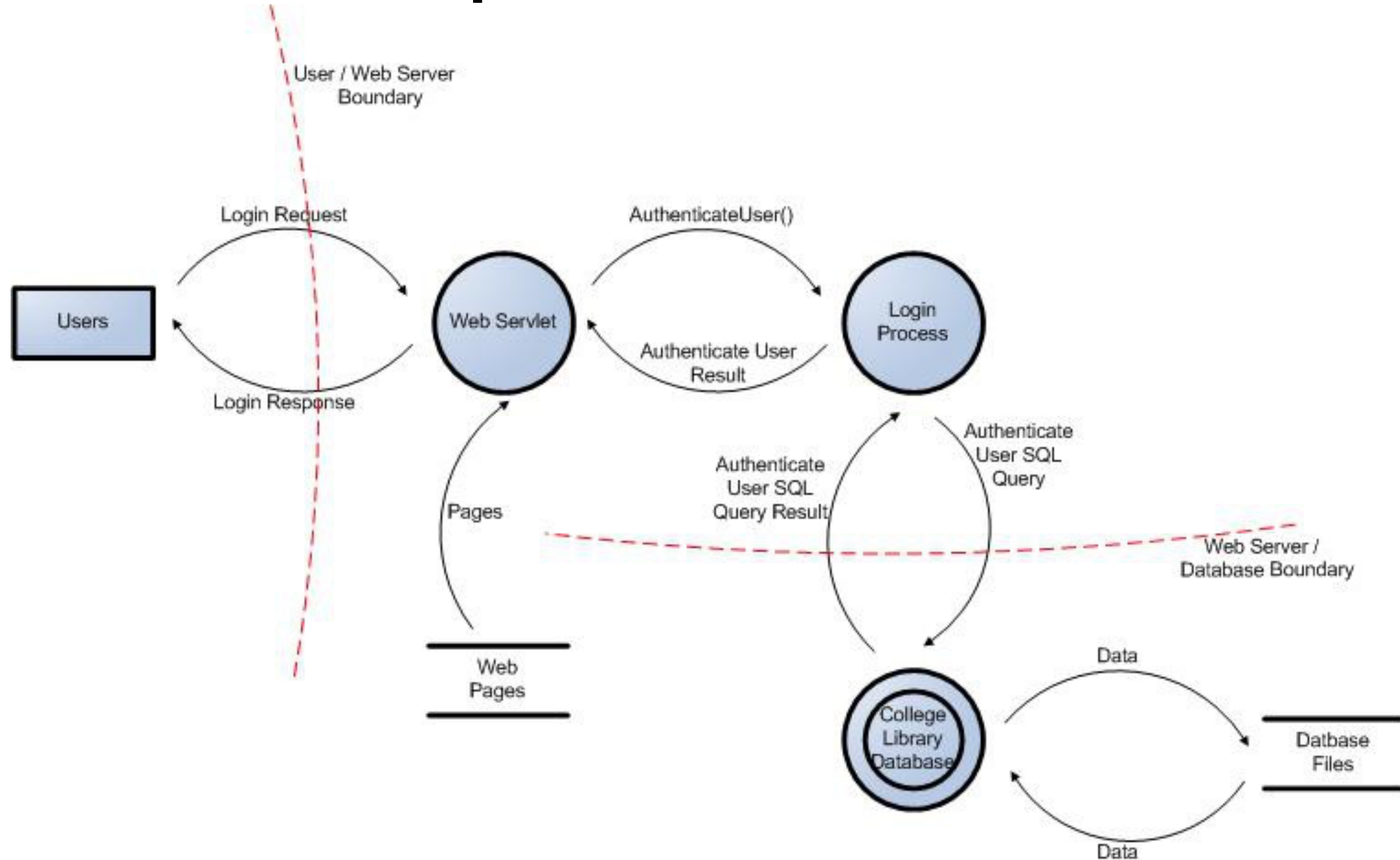
Data Flow Diagrams (DFDs)



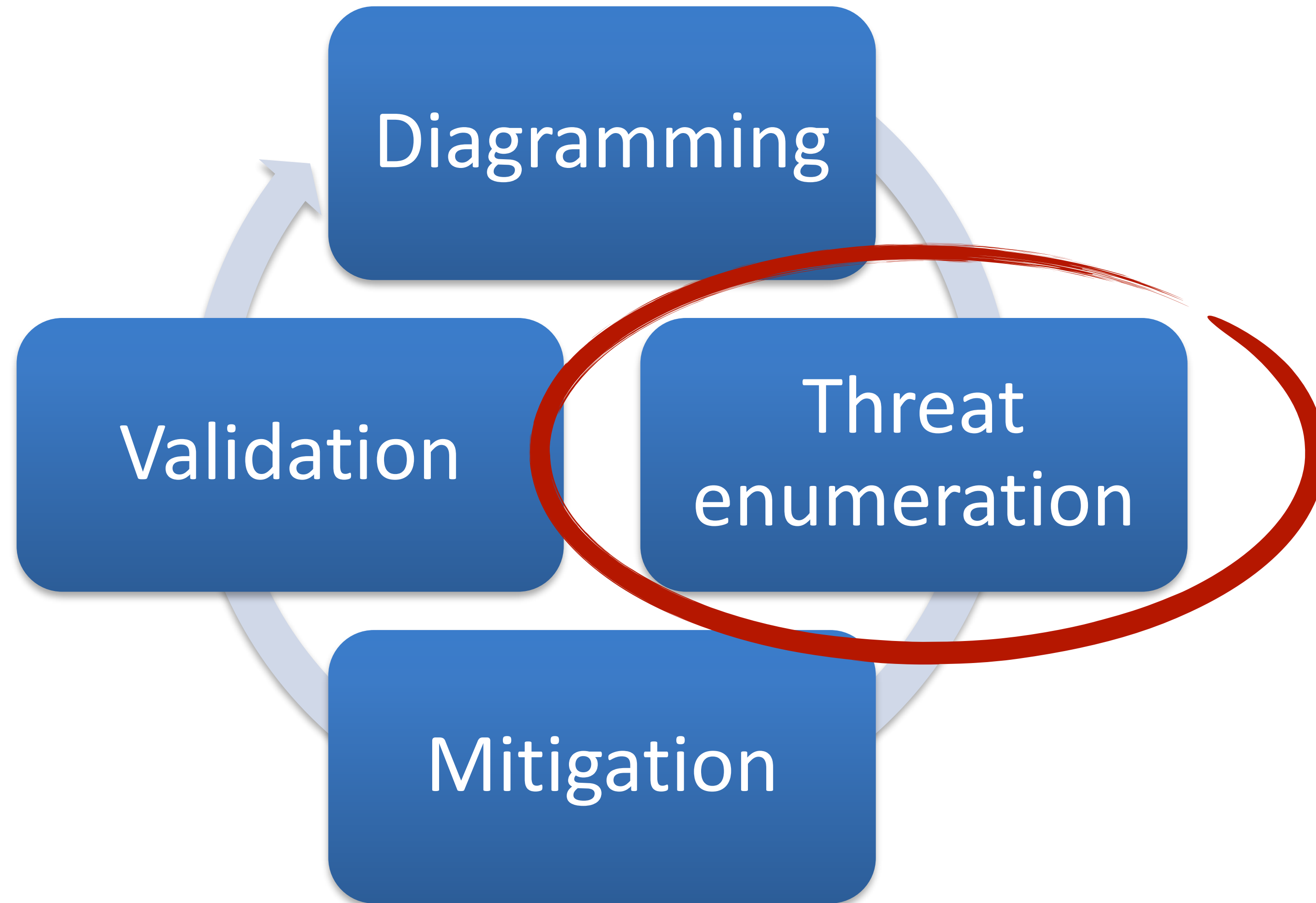
Example DFD



Another Example DFD



Threat Modelling



Spoofing

Tampering

Repudiation

Information Leakage

Denial of Service

Elevation of Privilege

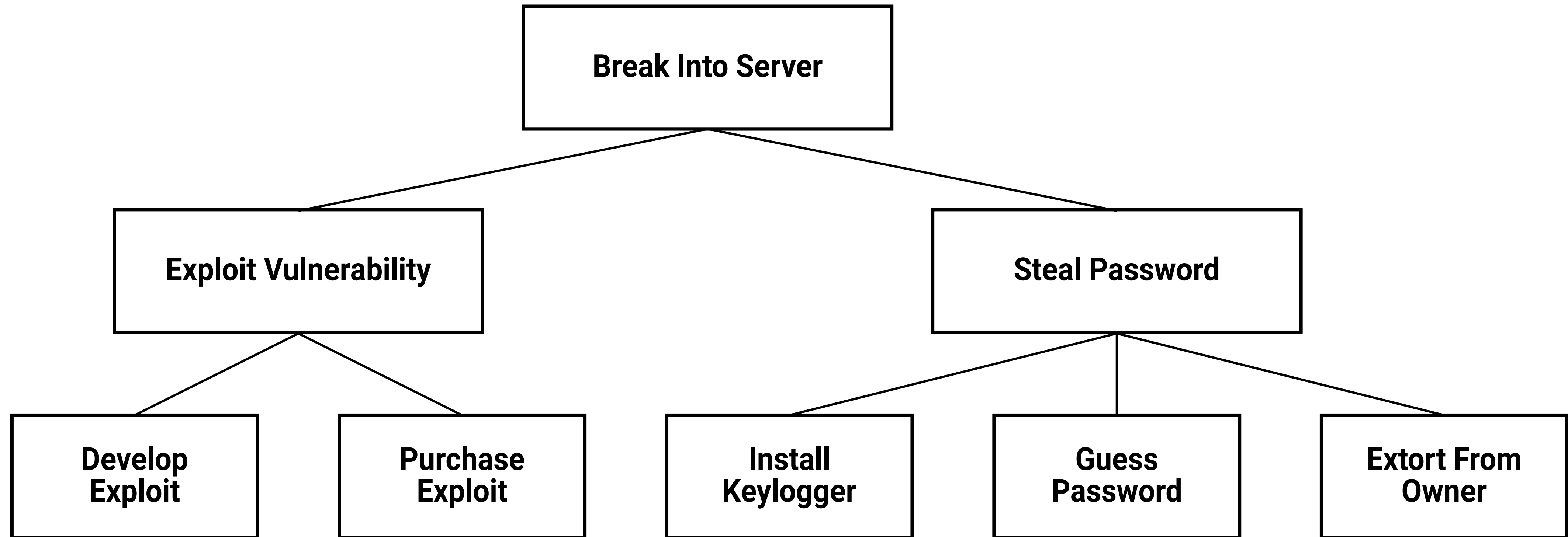
Data flows

Data stores

Processes

*Are your trust
boundaries
correct?*

Threat Analysis, e.g., Attack Trees



Threat Analysis, e.g., Misuse/Abuse cases

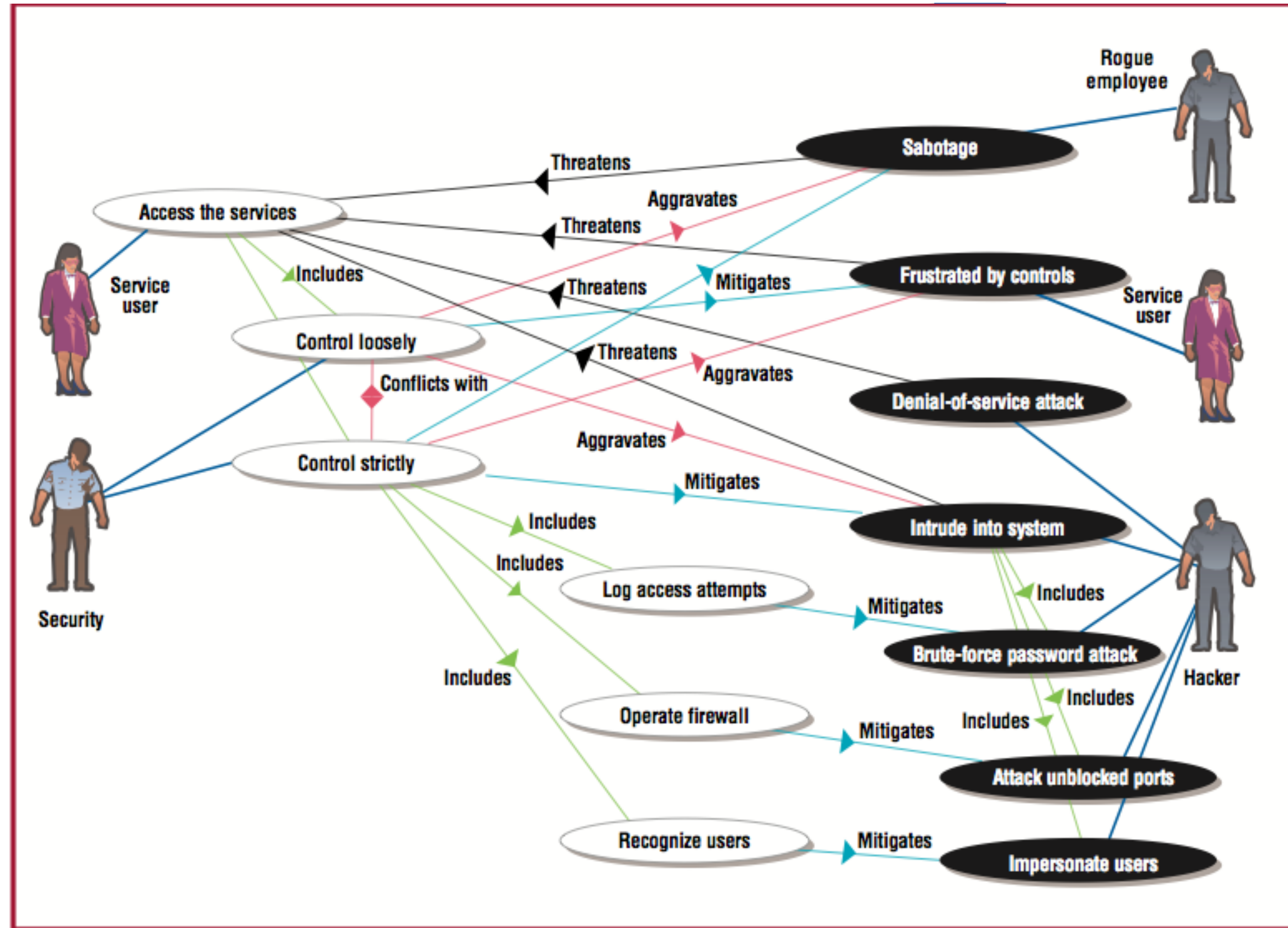
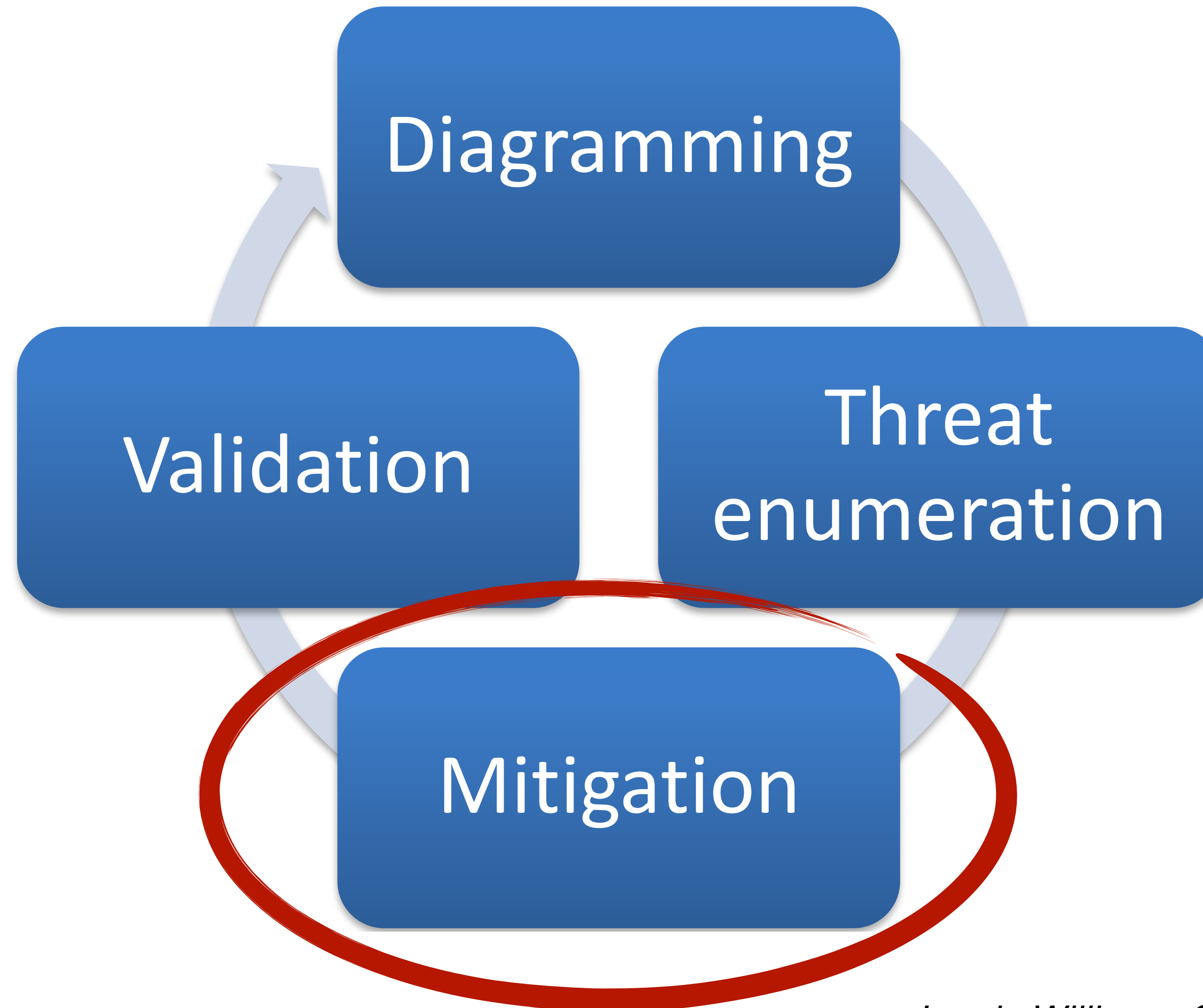


Figure 4. Use and misuse cases for Web portal security.

I. Alexander, *Misuse Cases: Use Cases with Hostile Intent*, IEEE Software, Jan/Feb 2003.

Threat Modelling



Spoofing

Tampering

Repudiation

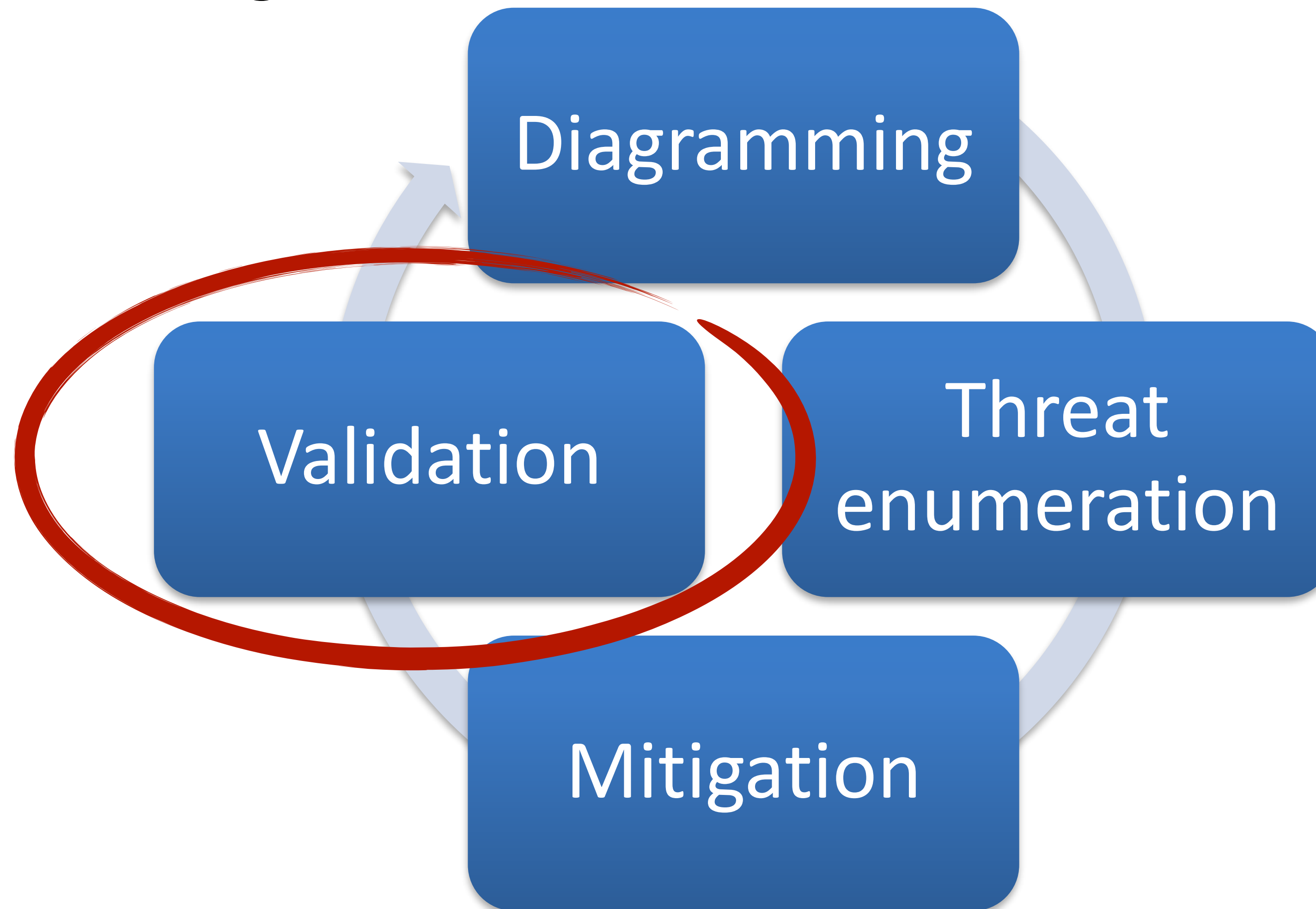
Information Leakage

Denial of Service

Elevation of Privilege



Threat Modelling



Lab - Using the Microsoft Threat Modelling Tool

1. Open the Microsoft Threat Modelling Tool
2. Prepare a DFD for the Juice Shop
3. Analyse the threats
4. Explore its features, e.g., report generation. You will need to have experience with the tool for your group assessment
5. If you are done with the Juice Shop, develop a threat model for this MSc Laboratory and analyse the threats.

Further Reading

<https://www.microsoft.com/en-us/securityengineering/sdl/practices>

<https://www.microsoft.com/en-us/securityengineering/sdl/threatmodeling>

[https://owasp.org/www-community/Threat Modeling Process](https://owasp.org/www-community/Threat_Modeling_Process)